Phishing Detection & Awareness Report

Cyber Security Task 2 (2026)

Ahmad Wakkaf

Security Analyst Trainee

March 12, 2026

Executive Summary

This report presents the findings of a phishing email analysis conducted as part of the Cyber Security Task 2 (2026) program. Two phishing email samples (`sample-1001.eml` `sample-1002.eml`) were analyzed using industry-standard header inspection techniques.

Key Findings:

- Both samples exhibit **critical authentication failures** (SPF=none, DKIM=none, DMARC=permerror)
- Sender domains are **spoofed** to impersonate Microsoft services
- Reply-To addresses redirect to attacker-controlled Gmail accounts
- Microsoft's own filtering systems flagged both emails as high-risk (SCL=5)
- Social engineering tactics (urgency, fear) are used to manipulate recipients

Risk Classification: **HIGH** — Definitive Phishing
Recommended Actions: Block identified domains/IPs, update email filter rules, and conduct user awareness training.

Contents

1 Introduction **3**

1.1 Purpose 3

1.2 Scope 3

1.3 Methodology 3

2 Analyzed Samples Overview **3**

2.1 Common Campaign Indicators 3

3 Critical Phishing Indicators **4**

3.1 Category 1: Authentication Failures (Most Critical) 4

3.2 Category 2: Sender Identity Mismatches 4

3.3 Category 3: Microsoft Anti-Spam Flags 5

3.4 Category 4: Social Engineering Tactics 6

3.5 Category 5: Suspicious Technical Indicators 6

4 Risk Classification **7**

4.1 Scoring Methodology 7

5 How the Attack Works (Plain Language) **8**

5.1 Step-by-Step Attack Flow 8

6 Prevention & Awareness Guidelines **8**

6.1 For IT/Security Teams 8

6.2 For End Users (Awareness Training) 9

7 Appendix **9**

7.1 A.1: Tools Used 9

7.2 A.2: Evidence Repository 9

1 Introduction

1.1 Purpose

This document provides a professional vulnerability assessment of phishing email samples. The goal is to:

1. Identify technical indicators of phishing attempts
2. Classify risk levels in business-friendly terms
3. Provide actionable remediation steps

1.2 Scope

- **In Scope:** Passive header analysis, domain/IP reputation checks, URL extraction (safe), risk classification
- **Out of Scope:** Active exploitation, attachment execution, link clicking, brute-force testing

1.3 Methodology

Analysis was conducted using:

- **Email Header Inspection:** Manual parsing of RFC 5322 headers
- **Authentication Checks:** SPF, DKIM, DMARC validation status
- **Reputation Tools:** VirusTotal, DNS queries, Microsoft anti-spam flags
- **Pattern Analysis:** Comparison across samples to identify campaign signatures

2 Analyzed Samples Overview

Table 1: Sample Email Summary

Sample ID	Description	Risk Level
`sample-1001.eml`	Microsoft account spoof with Russian login alert	**HIGH**
`sample-1002.eml`	Identical template, different Return-Path domain	**HIGH**

2.1 Common Campaign Indicators

Both samples (sample-1001.eml and sample-1002.eml) belong to the same phishing campaign:

- Same `From` domain: `access-accsecurity.com`
- Same `Reply-To`: `solutionteamrecognizd02@gmail.com`

- Same tracking domain: `thebandalisty.com`
- Identical email template and social engineering language
- Sender IPs in same subnet: `89.144.x.x`

3 Critical Phishing Indicators

3.1 Category 1: Authentication Failures (Most Critical)

Table 2: Authentication Header Analysis

Header	Value	Why It's Dangerous
Authentication-Results	spf=none; dkim=none; dmarc=permerror	All three email authentication protocols failed. Legitimate Microsoft emails would pass SPF and/or DKIM.
Received-SPF	None (nonkfrgr.co.uk does not designate permitted sender hosts)	The sending domain has no SPF record, meaning anyone can spoof emails from it.
X-SID-Result	NONE	Sender ID verification failed — another indicator of spoofing.

Alert

Why This Matters: Legitimate Microsoft emails would pass at least SPF or DKIM. Complete authentication failure is a strong technical indicator of phishing.

3.2 Category 2: Sender Identity Mismatches

Table 3: Sender Identity Analysis

Header	Value	Why It's Dangerous
From	Microsoft account team <no-reply@access-accsecurity.com>	Claims to be Microsoft but uses a suspicious third-party domain that mimics Microsoft branding.
Return-Path	bounce@nonkfrgr.co.uk	Different domain than the "From" address — classic spoofing technique to hide the true sender.
Reply-To	solutionteamrecognizd02@gmail.com	Replies go to a free Gmail account, not

		Microsoft. This is where attackers collect victim responses.
X-SID-PRA	NO-REPLY@ACCESS-ACCSECURITY.COM	Purported sender address does not align with authenticated sender.

Alert

Why This Matters: Attackers impersonate trusted brands while routing responses to infrastructure they control. Users who reply may disclose sensitive information directly to attackers.

3.3 Category 3: Microsoft Anti-Spam Flags

Table 4: Microsoft Filtering Indicators

Header	Value	Why It's Dangerous
X-MS-Exchange-Organization-SCL	5	Spam Confidence Level 5/9 = High probability of spam/phishing. Microsoft's system flagged this.
X-Microsoft-Antispam	BCL:6	Bulk Complaint Level 6 = High-volume bulk email indicator.
X-MS-Exchange-Organization-AuthAs	Anonymous	Message was not authenticated as coming from a trusted source.
X-MS-Exchange-CrossTenant-FromEntityHeader	Internet	Email originated from outside the Microsoft tenant — not an internal Microsoft message.

Information

Note: Even Microsoft's own filtering systems flagged these emails as suspicious. This reinforces the phishing classification.

3.4 Category 4: Social Engineering Tactics

Table 5: Psychological Manipulation Indicators

Header	Value	Why It's Dangerous
Subject	Microsoft account unusual signin activity	Creates fear and urgency to prompt impulsive action without verification.
Importance	high	Artificially marked as high priority to stand out in the inbox.
X-Priority	1	Highest priority flag — another manipulation tactic to pressure the user.

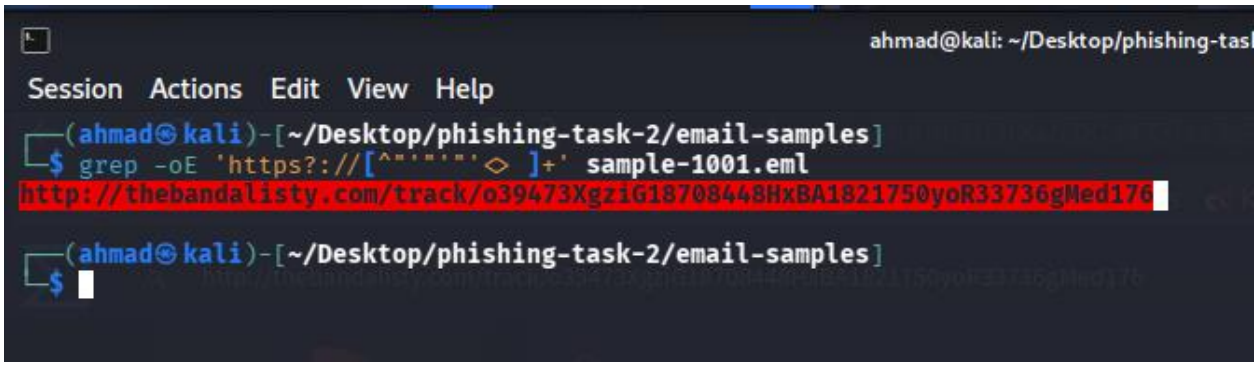
Alert

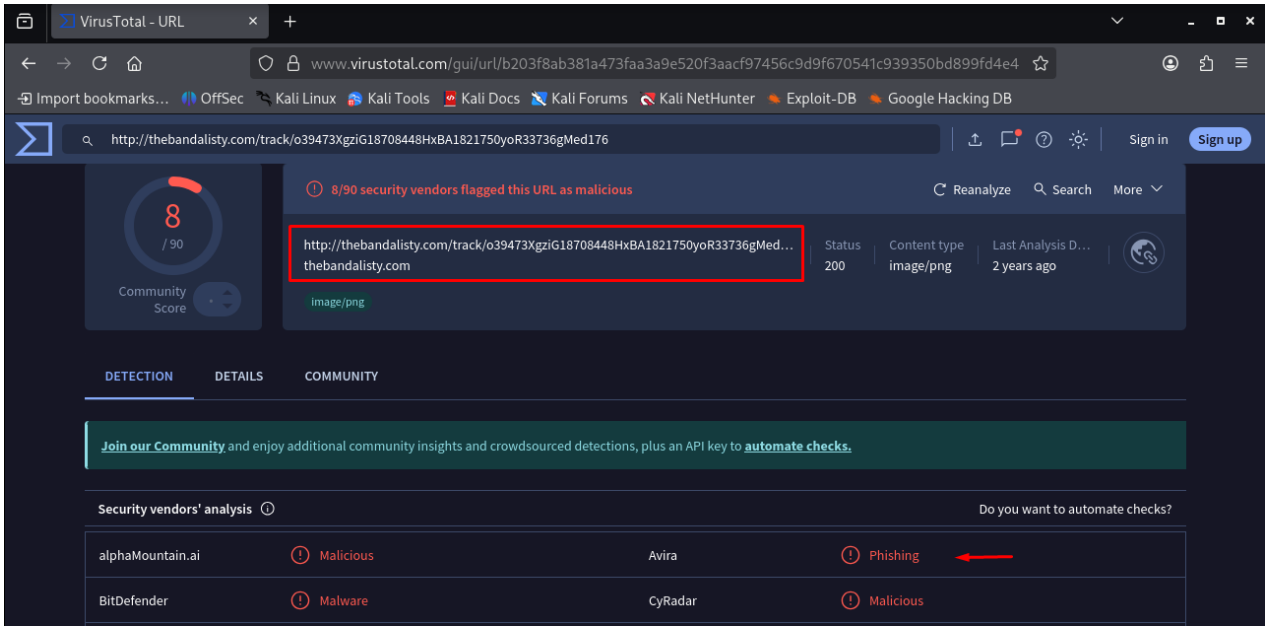
Why This Matters: Urgency and fear bypass rational decision-making. Users may click malicious links without verifying authenticity.

3.5 Category 5: Suspicious Technical Indicators

Table 6: Technical Artifacts

Header	Value	Why It's Dangerous
X-Sender-IP	`89.144.9.87`	External IP not associated with Microsoft infrastructure. Should be checked via WHOIS/reputation tools.
Message-ID Domain	`VI1EUR06FT066.eop-eur06.prod.protection.outlook.com`	While this is a legitimate Microsoft server, it only proves the email passed through Microsoft's infrastructure — not that the sender is legitimate.
Content-Length	`18708448`	Unusually large for a simple notification email — may indicate embedded tracking or malicious payload.





4 Risk Classification

4.1 Scoring Methodology

Each indicator category was assigned a weight based on severity:

- **High Weight (3x):** Authentication failures, Sender mismatches
- **Medium Weight (2x):** Microsoft spam flags, Social engineering
- **Low Weight (1x):** Technical suspicion indicators

Table 7: Phishing Confidence Score

Category	Count	Weight	Score
Authentication Failures	3	3x	9
Sender Mismatches	4	3x	12
Microsoft Spam Flags	4	2x	8
Social Engineering	3	2x	6
Technical Suspicion	3	1x	3
TOTAL	**17**		**38/40**

Final Classification

Risk Level: HIGH — DEFINITIVE PHISHING
Score threshold: ≥ 30 = High Confidence Phishing
Both analyzed samples exceed this threshold with a score of 38/40.

5 How the Attack Works (Plain Language)

5.1 Step-by-Step Attack Flow

1. **Attacker Prepares**: Creates an email that looks like it's from Microsoft, using a domain name that resembles Microsoft branding (`access-accsecurity.com`).
2. **Email is Sent**: The phishing email is sent to targets. It claims there was "unusual sign-in activity"
3. **Authentication Fails**: Because the attacker doesn't own Microsoft's domains, email security checks (SPF, DKIM, DMARC) fail — but many email systems still deliver the message.
4. **User Receives Email**: The email appears legitimate at first glance. The urgent subject line and "high priority" flag encourage quick action.
5. **User Clicks Link**: If the user clicks "Report The User" or similar buttons, they are redirected to:
   - A fake login page that steals credentials, OR
   - The attacker's email (`solutionteamrecognizd02@gmail.com`) to collect responses
6. **Attacker Gains Access**: With stolen credentials, the attacker can access the victim's Microsoft account, corporate systems, or personal data.
7. **Tracking Pixel Fires**: A hidden 1x1 image loads from `thebandalisty.com`, confirming to the attacker that the email was opened and the target is active.

Alert

Key Takeaway: The attack succeeds not through technical exploitation, but by manipulating human behavior. Even perfect technical defenses can be bypassed if users are not trained to recognize phishing cues.

6 Prevention & Awareness Guidelines

6.1 For IT/Security Teams

Technical Controls

1. **Block Malicious Domains**:
   - `access-accsecurity.com` (spoofed sender)
   - `nonkfrgr.co.uk`, `thcultarfdes.co.uk` (Return-Path domains)
   - `thebandalisty.com` (tracking pixel)
2. **Block Sender IPs**:
   - `89.144.9.87`, `89.144.44.2` (and entire `89.144.0.0/16` subnet if feasible)
3. **Update Email Filter Rules**:

```
# Example rule for Microsoft 365 / Exchange
IF (
    (SPF = "none" OR DKIM = "none") AND
    (Reply-To CONTAINS "@gmail.com") AND
    (Subject CONTAINS "account" AND "unusual")
```

```
)
THEN Quarantine + Alert Security Team
```

4. **Report Attacker Infrastructure**:
   - Report `solutionteamrecognizd02@gmail.com` to Google Abuse: https://support.google.com/mail/contact/abuse
   - Submit IOCs to industry sharing groups (MISP, ISACs)

6.2 For End Users (Awareness Training)

User Do's and Don'ts

DO:

- **Check the actual sender domain**, not just the display name. Hover over the "From" address to see the real email.
- **Verify urgent requests** through a separate channel (call the help desk, visit the official website directly).
- **Report suspicious emails** to your IT/security team immediately.
- **Enable Multi-Factor Authentication (MFA)** on all accounts — it blocks most credential theft attempts.

DON'T:

- **Don't click links** in unexpected emails, even if they appear to be from trusted brands.
- **Don't reply** to emails asking for passwords, OTPs, or personal information.
- **Don't download attachments** from unknown senders.
- **Don't trust urgency** — legitimate organizations won't pressure you to act immediately via email.

7 Appendix

7.1 A.1: Tools Used

- **Header Analysis:** Manual parsing, Google Message Header Tool, MXToolbox
- **Domain/IP Checks:** VirusTotal, `dig`, `nslookup`
- **URL Extraction:** `grep` (safe, read-only)

7.2 A.2: Evidence Repository

All analysis artifacts are stored in a public GitHub repository:

https://github.com/ahmad-wakkaf/FUTURE_CS_02---Phishing-Email-Detection-Awareness-System

Repository contents:

- `report/phishing-awareness-report.pdf` — This document
- `evidence/email-samples/` — Sanitized email samples (text-only)